ARP 實驗環境建置手冊

Windows 自行建置 · 學生版 · 第 1 組 g01

從啟動、登入與抓包，到驗證 ARP Spoofing 前後的封包變化。

課堂任務	需要留下的證據
實驗一　ARP Spoofing	截止前可辨識的受害端登入帳密
實驗二　路由器偵測與防護	告警紀錄，以及截止後仍有流量但無登入帳密的 PCAP

FHCST · 教材採 CC BY 4.0 授權。

目錄

步驟	內容	頁碼
1	準備 Docker 和專案	03
2	啟動並確認受害端正常運作	04
3	用遠端桌面登入攻擊端	05
4	確認網站與核對帳密	06
5	確認編輯器和 SSH	07
6	兩項實驗與驗收	08
7	停止錄製並檢查 PCAP	09
8	卡住時先查哪裡	10

開始前先確認

本手冊以你在自己的 Windows 電腦啟動 Docker 為例。如果老師已架好環境，使用老師給的主機位址、連接埠和帳密，從第 3 步開始。重啟錄製與停止環境的指令由 Docker 主機操作者執行。

1. 準備 Docker 和專案

1. 安裝並開啟 Docker Desktop，選用 **WSL 2** 後端及 **Linux containers**。若安裝程式要求重新開機，完成後再打開 Docker Desktop。 Windows 安裝指南
2. 開啟 **Windows PowerShell**，確認 Docker 引擎可用、Compose 至少為 **2.36**。 Compose 網卡命名需求

```
docker version
docker compose version
```

`docker version` 應顯示 **Client** 和 **Server**，Server 的作業系統應為 Linux。初次啟動需要網路下載映像。

3. 從專案頁選 **Code → Download ZIP**，解壓縮後將資料夾命名為 `arp-lab`。 以解壓到「下載」資料夾為例，在 PowerShell 進入含有 `compose.yaml` 的那層。若存放位置不同，請換成自己的路徑。 ARP Laboratory 專案

```
cd "$HOME\Downloads\arp-lab"
Get-ChildItem -Name
```

Project layout — PowerShell

```
PS> Get-ChildItem -Name | Where-Object {
    $_ -match "^(compose.*\.yaml|containers|docs|captures)$"
}
captures
containers
docs
compose.build.yaml
compose.g01.yaml
compose.g02.yaml
compose.services.yaml
compose.yaml
```

圖 1　主要檔案包含 Compose 設定、容器來源、教材和抓包目錄。

2. 啟動並確認受害端正常運作

在專案根目錄執行。第一次會從 GHCR 下載適合 CPU 架構的預先建置映像，等指令返回後再檢查狀態。

```
docker compose config --services
docker compose up -d
docker compose ps
```

預設啟動 `g01`，服務清單會有下表五項。名稱以 `g01-` 開頭是為了區分各組。

服務	實驗 IPv4	用途
`g01-victim`	`10.0.0.10/16`	自動造訪網站，產生 HTTP 流量
`g01-attack`	`10.0.0.20/16`	學生登入操作的 XFCE 桌面
`g01-router`	`10.0.10.254/16`、`203.72.59.254/24`	連接內外網並抓包
`g01-server`	`203.72.59.10/24`	提供實驗網站
`g01-access`	`10.0.0.30/16`	將 Windows 的 SSH 與 RDP 轉到攻擊端



圖 2　節錄測試環境的 Service、State 與 Health 欄，五項服務都應在執行。

```
docker compose logs --tail 10 g01-victim
```

看到 `index -> login -> admin action -> logout OK` 才算網站流程跑通。若清單只有空白，等幾秒再執行一次。



圖 3　受害端每次完成整套流程，就會新增一行 OK。

3. 用遠端桌面登入攻擊端

在 Windows PowerShell 開啟「遠端桌面連線」。本機 `g01` 預設使用 TCP `13389`。

```
mstsc /v:127.0.0.1:13389
```

若顯示憑證警告，先核對視窗中的目標是否為自己剛啟動的本機實驗。遠端課堂環境請依老師提供的位址及連線方式核對。

在 **xrdp** 登入畫面選 **Xorg**，輸入帳號 `student`。本機預設密碼為 `demo-desktop-password`。若你或老師有改過設定，使用實際配發的密碼。



圖 4　Session 選 Xorg。這組帳密用於攻擊端桌面與 SSH。

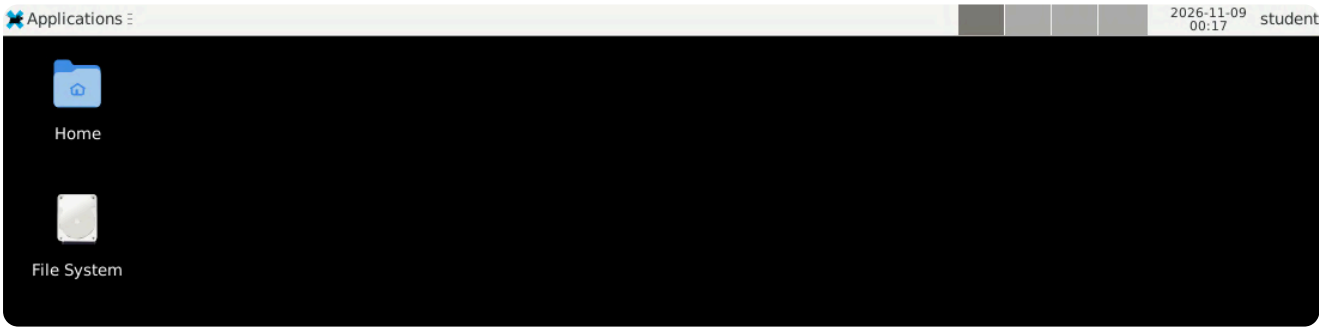


圖 5　登入成功後，會看到 XFCE 桌面與 Applications 選單。

也可從本機瀏覽器開啟 `http://127.0.0.1:6080/vnc.html`，使用獨立的 VNC 密碼 `labvnc01` 連線。

4. 確認網站與核對帳密

1. 從 XFCE 的 **Applications** 開啟 **Firefox**。若出現首次使用畫面，完成設定後，在網址列輸入 `http://203.72.59.10/`，確認看到「ARP 實驗網站」。
2. 開啟 `http://203.72.59.10/admin/login.php`，用自己的**實驗網站帳密**登入。本機預設帳號為 `admin`，密碼為 `demo-http-password`。若你在 `.env` 改過設定，使用 `LAB_WEB_USER` 與 `LAB_WEB_PASSWORD` 的實際值。

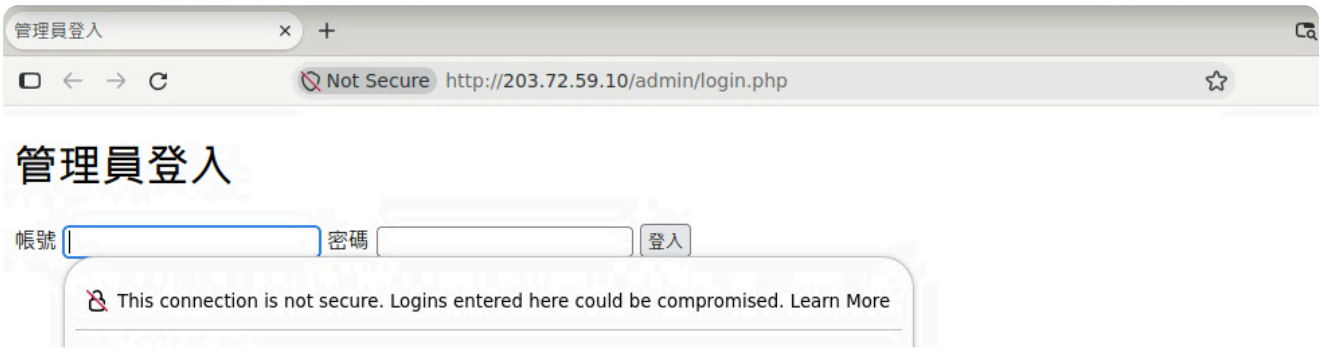


圖 6　先確認這組網站帳密能登入，稍後用它核對封包中的欄位。

3. 進入「管理面板」後，點一次「記錄一次操作」，確認計數增加，再按「登出」。第 6 步會重啟錄製，把這次手動登入留在舊檔。

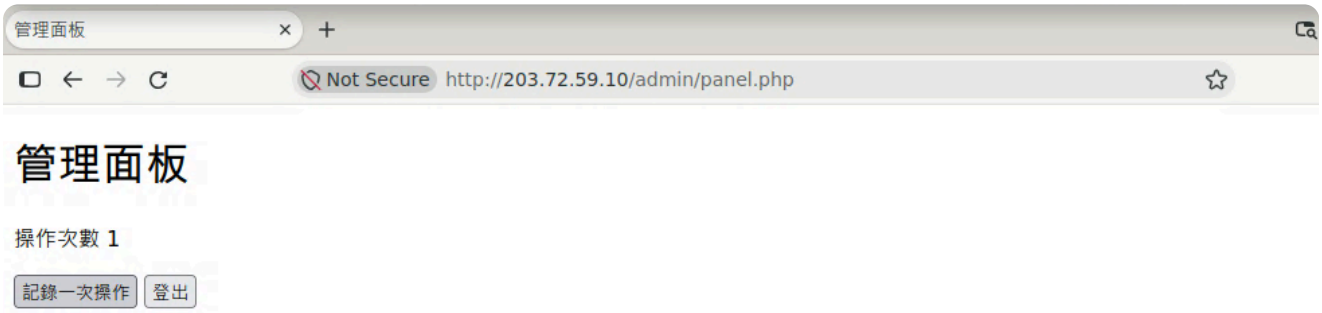


圖 7　看到管理面板並能操作計數，即完成開始前的網站檢查。

5. 確認編輯器和 SSH

公開映像預裝 **VSCodium**，這是基於 Code - OSS 的 MIT 編輯器。在 XFCE 的 **Applications** 開啟 VSCodium，或在 **XFCE 終端機**用下列指令開一個 Python 檔。專案提供的 `code` 指令會啟動 VSCodium。

```
code ~/lab-check.py
```

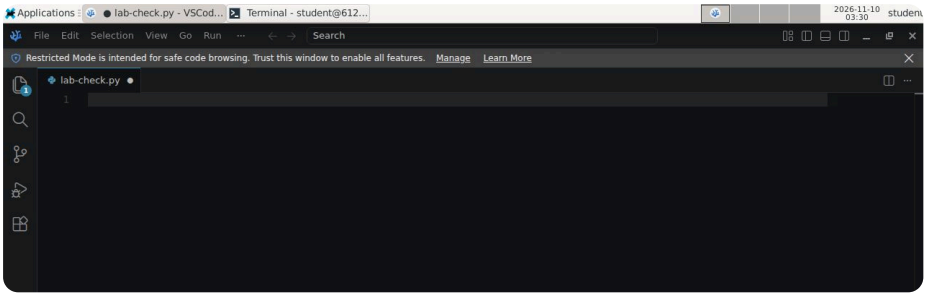


圖 8a　code 指令會在 VSCodium 開啟指定的檔案。

切到 `lab-check.py` 分頁，可先輸入 `print(1)` 並按 Ctrl+S 儲存，確認檔案可編輯。使用 SSH 執行需要原始封包權限的程式時，可依實驗需求使用 sudo。

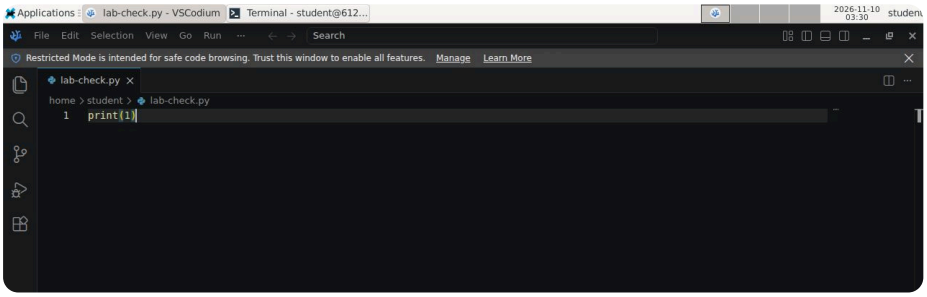


圖 8b　輸入並儲存簡單的 Python 敘述，確認編輯器可用。

如果老師已提供遠端環境，SSH 請使用老師提供的主機和 SSH 埠，或直接使用已登入的 XFCE。若在自己電腦建置，可另開一個 **Windows PowerShell** 視窗，用 SSH 連入同一台攻擊端。

```
ssh -p 2222 student@127.0.0.1
```

第一次連線若詢問是否信任主機金鑰，先確認連的是剛建立的本機容器，再輸入 `yes`。重建後若出現主機金鑰已變更，也要先核對目標，確認是自己剛重建的本機實驗後，可用 `ssh-keygen -R '[127.0.0.1]:2222'` 清除舊記錄再重連。登入後，在 **SSH 工作階段**執行：

```
whoami
python3 --version
python3 -c "import scapy; print(scapy.__version__)"
exit
```

`whoami` 應顯示 `student`，後兩個指令分別顯示 Python 和 Scapy 版本。`exit` 會回到 Windows PowerShell。

6. 兩項實驗與驗收

先開一份新的錄製

完成第 4 步的手動登入與登出後，在 **Windows PowerShell** 的專案根目錄執行。第一行送出 `SIGUSR1`，只重啟錄製程序。

```
docker compose kill -s SIGUSR1 g01-router
docker compose logs --tail 10 g01-router
docker compose logs --since 30s --timestamps g01-victim
```

第一行可能顯示 `Killed`，表示 Compose 已送出指定的訊號。等 router 紀錄出現新的 `Recording` 行，記下兩項實驗共用的 `lan.{timestamp}.pcap`。檔名時間是 UTC。確認 victim 在新檔建立後出現 `logout OK`，再從攻擊端的 XFCE 終端機開始實驗。兩項實驗之間維持錄製。

實驗一 | 實作 ARP Spoofing

讓受害端將攻擊端的 MAC 誤認為預設閘道，也讓路由器將攻擊端的 MAC 誤認為受害端。記下攻擊開始時間和鄰居項目的變化，確認 victim 仍能完成網站流程。router 平時就能看到明文 HTTP，請一併保留鄰居項目變化或偽造的 ARP 回覆作為攻擊證據。

驗收目標　用第 7 步的篩選器找出攻擊期間受害端的登入 POST，記下封包編號與時間，並將表單的帳密與第 4 步已驗證的值比對。

實驗二 | 在原環境加入路由器防護

沿用同一組容器、IP、網站與錄製檔。讓 router 偵測 ARP Spoofing 並採取防護。記下告警時間、防護生效的**截止時間**與觀察結束時間，並在觀察區間內持續攻擊及 victim 測試。保留告警及防護命中的證據。

驗收目標　截止前找得到受害端的登入帳密。截止後在同一份 PCAP 仍可看到受害端的測試流量，例如嘗試連線的 TCP SYN，但看不到新的登入帳密。若 router 在 `lan0` 仍錄到完整表單，即使轉發已遭阻擋，PCAP 仍可讀到帳密。

7. 停止錄製並檢查 PCAP

在 **Windows PowerShell** 的專案根目錄停止 Compose。router 會結束錄製，PCAP 已在 Windows 的專案資料夾中。若自訂 `ARP_LAB_ENV_G01_NAME`，把下方 `captures/g01` 的 `g01` 改成自訂名稱。

```
docker compose down
Get-ChildItem .\captures\g01\lan.*.pcap
```

```
Router capture                                    PowerShell
PS> Get-ChildItem .\captures\g01\lan.*.pcap
Length Name
------ ----
282408 lan.20261110T032823Z.pcap
301048 lan.20261110T032952Z.pcap
```

圖 9　每次開始錄製都有自己的檔名。開啟第 6 步記下的那一份。

在 Wireshark 找到登入表單

在主機安裝 Wireshark，開啟第 6 步記下的檔案。將下列整行貼到 **顯示篩選器**並按 Enter。 Wireshark 下載

```
ip.src == 10.0.0.10 && ip.dst == 203.72.59.10 && http.request.method == "POST" && http.request.uri == "/admin/login.php"
```

1. 在封包清單選取**攻擊開始後、截止前**的 `POST /admin/login.php`。來源是 victim `10.0.0.10`，目的地是網站 `203.72.59.10`。手動核對帳密的來源是攻擊端 `10.0.0.20`。
2. 在封包詳細資料展開 **HTML Form URL Encoded**，查看 `username` 和 `password`。也可右鍵選 **Follow → TCP Stream**，在 `POST /admin/login.php` 下方找表單本文。開登入頁的 GET 與操作面板的 POST 都是其他請求。
3. 用同一篩選器檢查截止後是否仍有帶帳密的登入 POST。要確認該區間仍有連線嘗試，可用 `ip.src == 10.0.0.10 && ip.dst == 203.72.59.10 && tcp.dstport == 80 && tcp.flags.syn == 1 && tcp.flags.ack == 0`。

```
Victim login request                                      TShark
Frame 24  10.0.0.10  203.72.59.10  POST  /admin/login.php
HTML Form URL Encoded: application/x-www-form-urlencoded
Form item: "username" = "admin"
Form item: "password" = "demo-http-password"
```

圖 10　測試 PCAP 的表單解碼。請依自己的攻擊時間找出對應封包。

交付 PCAP、登入封包編號與時間、帳密核對結果、告警與截止時間，以及截止後仍有測試流量的證據。比對時間前，先確認 Wireshark 和實驗筆記採用相同時區。

8. 卡住時先查哪裡

現象	先檢查這一項
`docker version` 只有 Client 或連不上 Docker	打開 Docker Desktop，等引擎啟動，確認使用 Linux containers。
`no configuration file provided`	確認 PowerShell 所在的資料夾看得到 `compose.yaml`。
`g02-victim` 找不到	專案預設只載入 `g01`。以 `docker compose config --services` 顯示的服務名稱為準。
連接埠被占用	若還沒有 `.env`，用 `Copy-Item .env.example .env` 建立。編輯 `LAB_SSH_PORT_G01` 或 `LAB_RDP_PORT_G01`，重跑 `docker compose up -d`，再用新埠連線。
本機 RDP 連不上	用下方的 `docker compose port` 指令查實際入口。輸出如 `127.0.0.1:13389`，RDP 用輸出右側的主機埠。再確認 `g01-access` 和 `g01-attack` 正在執行。
同學的電腦連不到你這台	專案預設綁定 `127.0.0.1`，只能從 Docker 主機登入。使用老師提供的遠端入口。
網站打不開或受害端一直重試	從 XFCE 內的 Firefox 開啟完整的 `http://203.72.59.10/`，再查 `g01-router`、`g01-server` 與 `g01-victim` 的紀錄。
建立 macvlan 網路失敗	記下 Docker Engine 版本和完整錯誤，交給老師確認相容環境。此專案在 Windows 的 Docker Desktop Linux 引擎實測可用，但 Docker 官方未將 Docker Desktop 列為 macvlan 支援平台。

```
docker compose ps -a
docker compose port g01-access 13389
docker compose logs --tail 30 g01-access g01-attack
docker compose logs --tail 30 g01-router g01-server g01-victim
```

Docker macvlan 平台說明

完成檢查

- [ ] 五個服務都能啟動，且 victim 紀錄出現 `logout OK`。
- [ ] 能登入 XFCE，並在開始錄製前核對網站帳密。
- [ ] 能在 VSCodium 開檔，並開啟實驗用 `lan.{timestamp}.pcap`。